

ISYS90090 · CYBERSECURITY MANAGEMENT

Incident Response

How organisations respond,
and why response fails.

Week 10 · Atif Ahmad · University of Melbourne



This Week in Cybersecurity Management

01

Study Canvas
Module 10

02

Prescribed
reading: pp.
186–222

03

OPTIONAL

Answer
discussion
questions on
Canvas, and
chat with
peers

04

Attend the
workshop

05

OPTIONAL

Continue the
discussion
with peers on
Canvas

This week's workshop

PART A

Q&A session
on this week's
content

PART B

Quiz

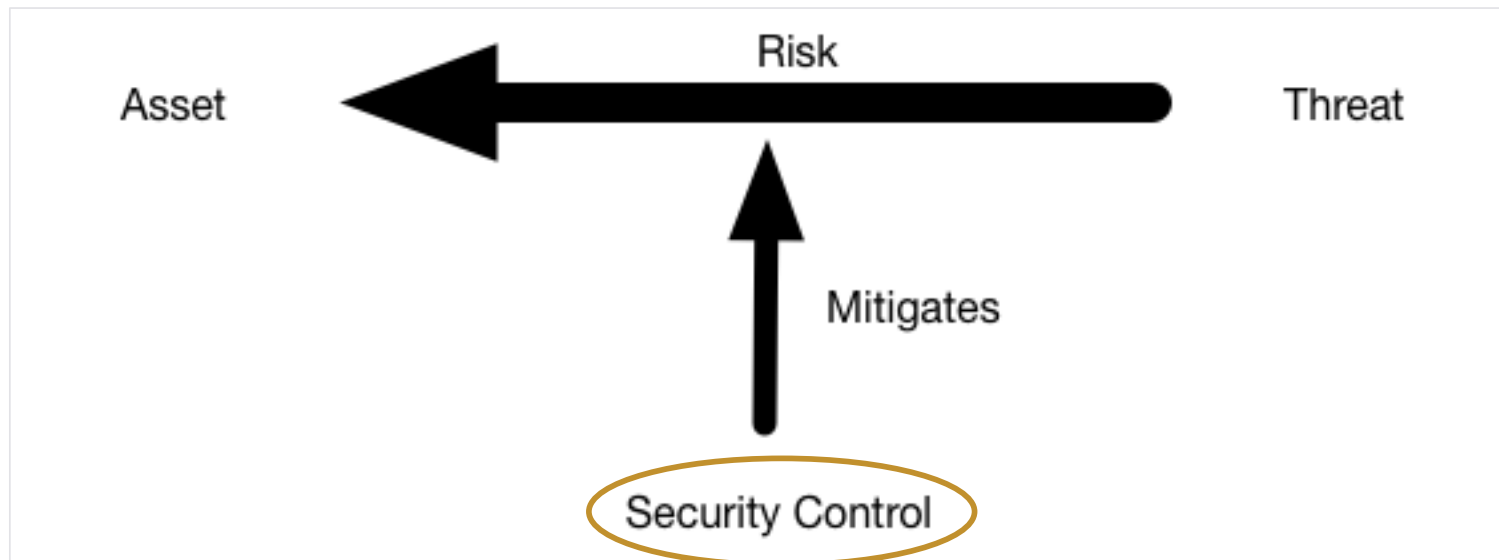
PART C

Incident
response
activity

Intended Learning Objectives

- 01 Critically analyse the means, motivations and capability of threat actors
- 02 Describe the key operational phases of an organised and sophisticated attack
- 03 Identify the key phases of an incident response process
- 04 Analyse the incident response management practices of an organisation
- 05 Construct recommendations regarding the incident response management practices of an organisation

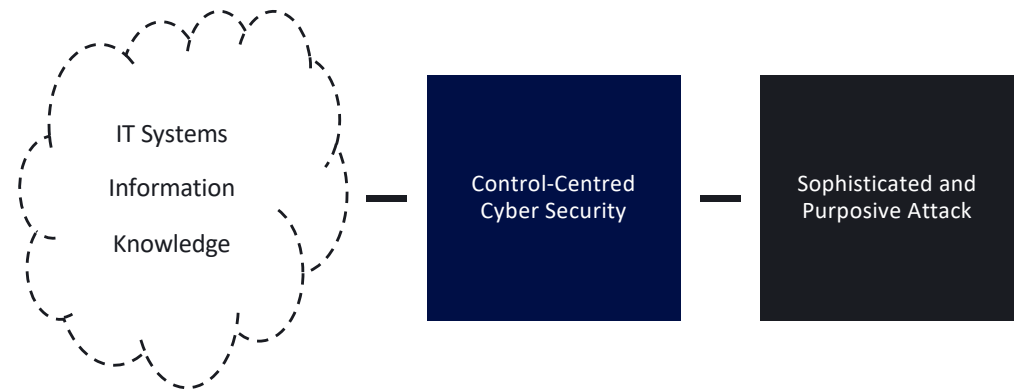
What kind of control is incident response?



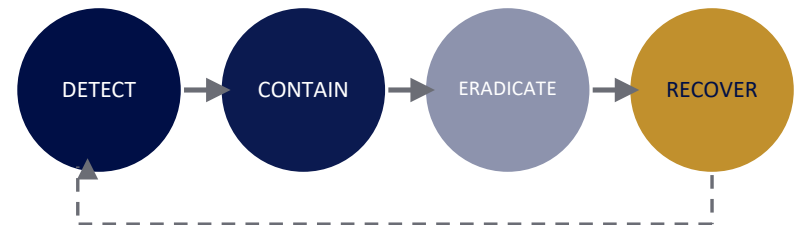
Incident response is not a preventative control.

Cyber security at a strategic level

Prevention: Build a 'shield' of safeguards to block broad spectrum of threats

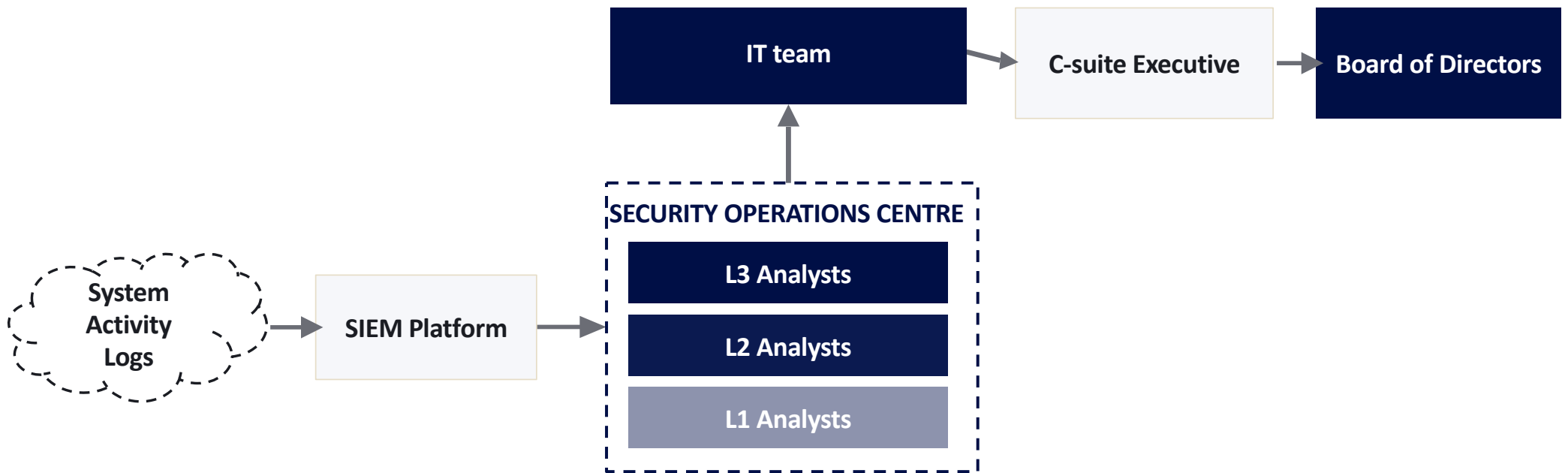


Response: Operational-Response to Breaches is to Restore Control-centered Cyber Security 'Shield' and routine business operations



How organisations first built response.

The early model. Most organisations started here, and many are still here.



*Alerts climb the technology stack and reach the executive as a status report.
Nobody between the logs and the board is asked what the attacker was after.*

WHERE WE LEFT OFF

Incident response runs like an emergency department.

So busy seeing a large volume of patients that nobody sees the pattern arising from an organised, persistent attack.

ONE

Something is noticed

A ticket from the help desk, an alert someone escalated, or a customer complaint. The organisation learns it has a problem from whoever happened to be looking.



TWO

Diagnose and prioritise

Work out what kind of incident it is, and how urgent it is against everything else in the queue. The goal is to rank it, not to understand who is doing it.



THREE

Contain, eradicate and recover

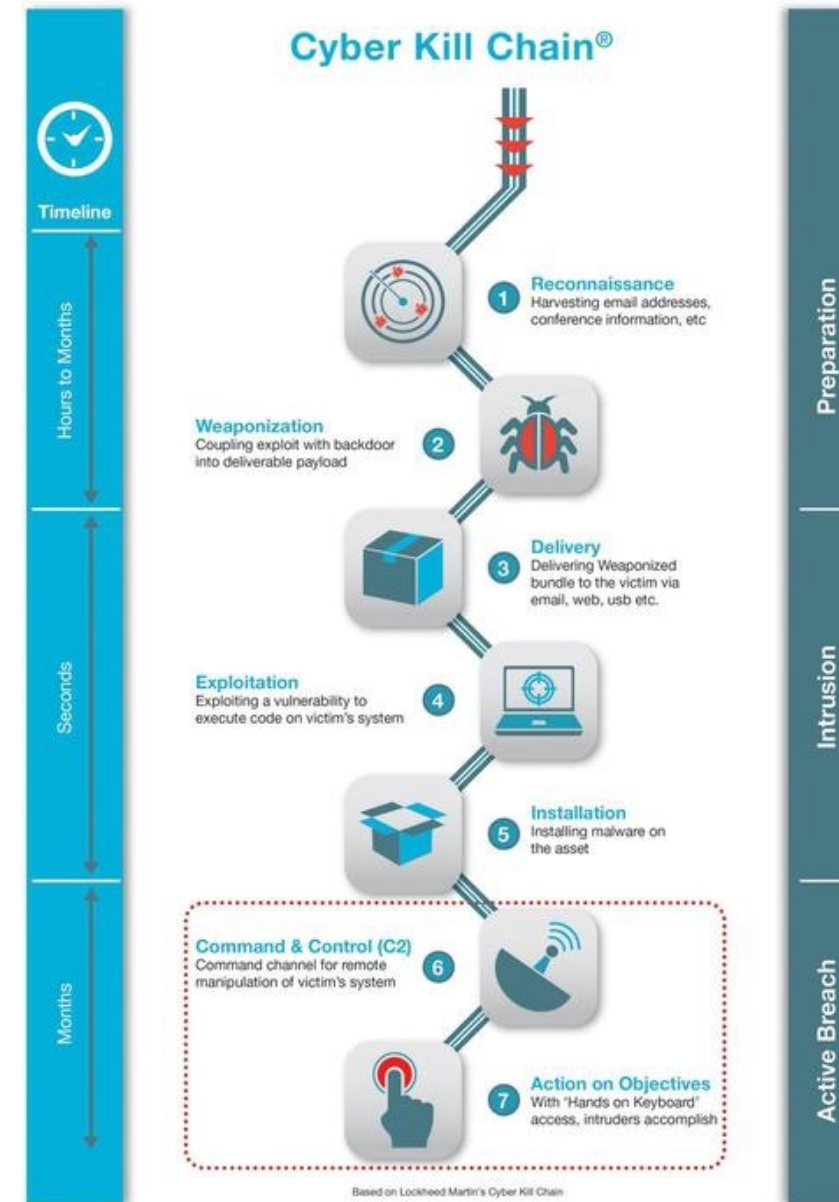
Stop it spreading, remove it, and bring the service back. The ticket is closed, and as far as the business is concerned the incident is over.

How do you shift from reactive to proactive? From tactical to strategic? That question runs the rest of the day.

HOW ORGANISATIONS RESPOND, AND WHY RESPONSE FAILS

Kill Chain

What is the attacker doing?



BEFORE THE FINDINGS

What is known, and what research was done in UoM

Before the findings, the question. It explains why we went looking where we did.

AROUND 2005

Where the field stood

Incident response was a small technical team.

Its job was continuity: keep systems and networks running.

After an attack, bring the services back up. That was all.

THE QUESTION WE ASKED

Asymmetry

APTs were attacking private enterprise

Not a fair fight! Who can survive?

How can we level the playing field?

WHAT WE DID

Then we went deep

From 2006 to 2019, incident response was one of many projects we ran.

In 2019 we made it the focus: a major field study that immersed us in the problem.

What follows comes from inside two banks.

From the next slide on, everything you see came out of that fieldwork, with the interviews behind every claim.

Nothing after this is borrowed from a framework.

THE FIELD RESEARCH

The findings start here.

Two banks, studied from the inside. Everything from this slide on is evidence from the fieldwork, not opinion and not a framework.

Two banks. Same sector, same attackers.

Same risk profile, same regulatory pressure, same threat actors. Two completely different operating models. The labels denote assessed response maturity; the research was conducted in Australia and Indonesia.

BANK H

Fully insourced. Empowered. Integrated.

- Insourced 24/7 operations centre at L1, L2 and L3
- Dedicated threat intelligence team
- Security Leadership Team forms on demand
- Direct access to twelve domain leads

BANK M

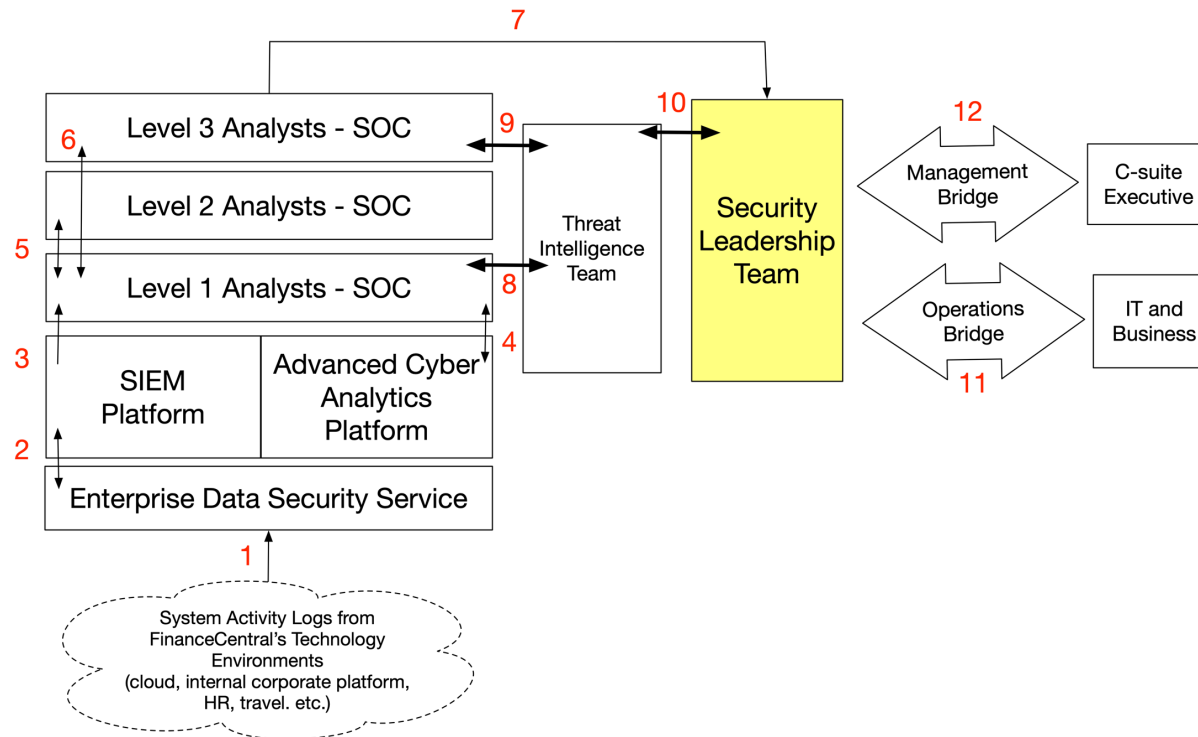
Hybrid. Outsourced specialists, internal coordination.

- Outsourced L1 to L3 operations centre
- Outsourced threat intelligence
- Outsourced forensics on retainer
- Six-person internal coordination team

Same regulator. Same attacker pool. What differs is structure, and at least sixty per cent of large organisations globally run the second model.

The Fully Insourced Configuration

A multinational bank, forty thousand staff, twenty five billion events a day. The budget is large. What matters is what the structure does with it.



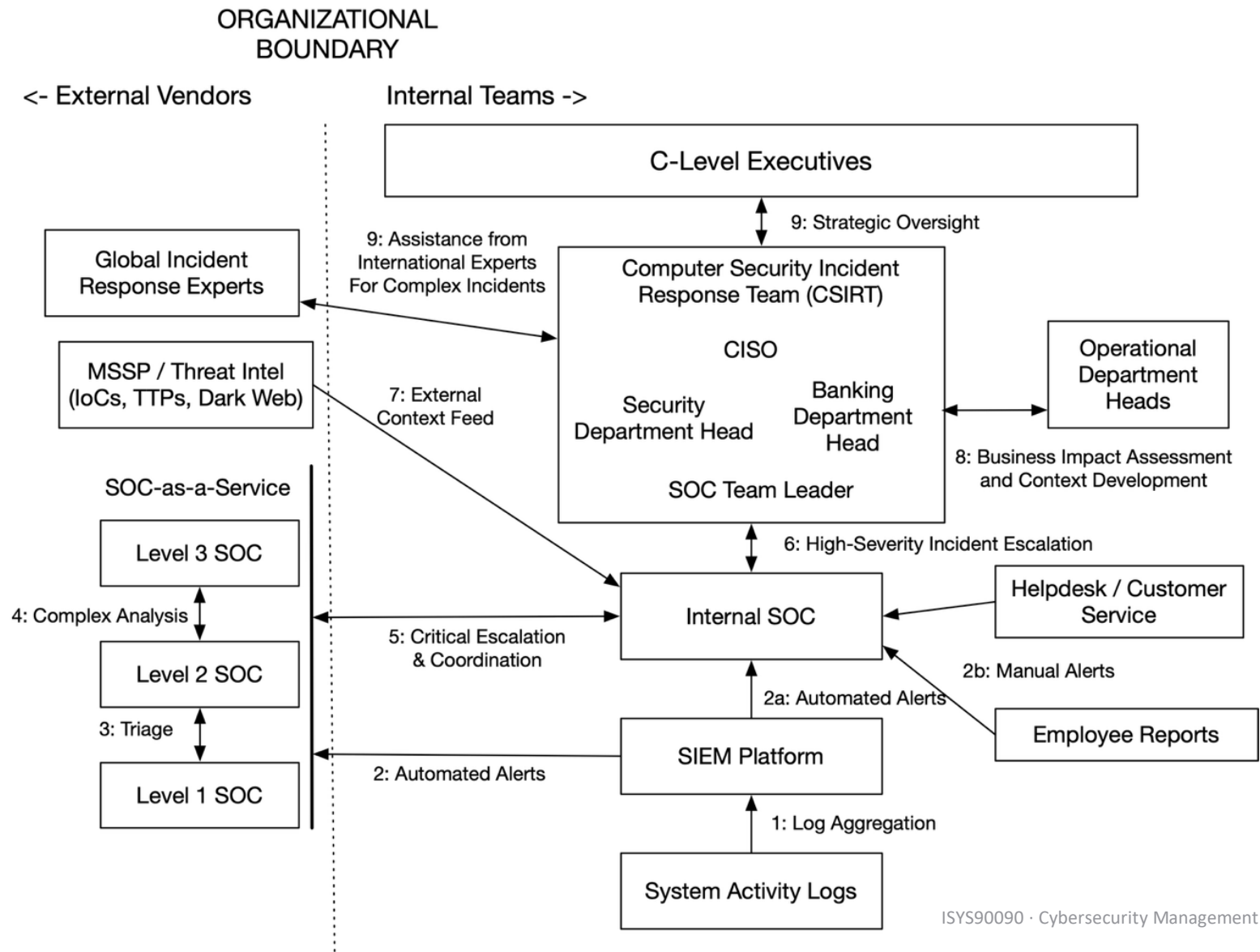
Everyone important is in the war room.

1	Authority, and the two-bridge architecture	The operations lead can engage any of twelve domain leads directly, at any hour. The Security Leadership Team forms within the hour. An operations bridge runs to the domain heads, a management bridge to the CISO and senior executive. Decisions are made by the people who know the incident, while it is still running.
2	Threat intelligence integrated at three levels	A team of four to six feeds operational intelligence to L1, tactical intelligence to L3, and strategic intelligence to the leadership team. Connected to intelligence agencies, government, law enforcement and commercial specialists. Intelligence directs the investigation rather than consuming its output.
3	Blind spots eliminated on purpose	The firm maps its visibility gaps continuously and engineers custom logging to fill them. Perception is treated as a capability to be built in-house.
4	Senior executives supply business context	When motive is unclear or an asset's significance is not technically obvious, executives supply the strategic context, the intangible value and the pending business decisions.

The lever here is structure, authority, and the habit of putting the right people in one room. The budget is beside the point.

The Hybrid

At least sixty per cent of large organisations globally run this model, and the share is higher in developing economies. This is what most of the world looks like.



The experts are outside the war room.

- | | | |
|---|--|--|
| 1 | Perception is sound. Comprehension breaks. | Four teams collect raw data well. Specialisation works. The problem begins when those signals have to be integrated into shared meaning. |
| 2 | The experts are not in the room where decisions are made | The response team is the CISO, the security head, the operations lead and business heads. The vendor's most senior analyst, who does the deepest technical work, is absent. So is the intelligence analyst. So are the forensic experts. |
| 3 | Information flow is transactional, not transformational | Vendors deliver reports. The internal team consumes them. There is no feedback, so the vendor never learns what was useful and collection is never refined. |
| 4 | Sensemaking is sequential, not collaborative | Each handoff filters context and adds delay. What reaches the decision room is a compressed and lossy version of what the technical experts actually understood. |

The lever is engagement across the boundaries. Changing the sourcing model will not reach it.

WHAT THE RESEARCH FOUND

Three gaps. Every organisation we studied had at least two.

LEADERSHIP

The enterprise is not engaged with the response.

You restore the service and never ask what it cost you.

ENGAGEMENT

The threat environment is not engaged with at all.

You know what happened. You do not know who, or why, or whether they are coming back.

INSTITUTIONALISATION

The incident does not change the organisation.

The same shape of incident is already queued up to recur.

All three are closed by structure.

Thank you

Incident response: how organisations respond, and why response fails.

ISYS90090 · Cybersecurity Management · Week 10

